ACC-06 · Identity Verification Before Any Account Action

How IT establishes that a person asking for access is who they say they are, before anyone touches the account.

Field	Value
Document ID	ACC-06
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 1 — the Service Desk, and every tier that touches an account. No tier is exempt.
Review cycle	Annually, and after any attempted social-engineering incident.

1. Purpose

This document states how IT establishes that a person requesting an account action is who they claim to be, and what is recorded about it. Many desks have no written procedure for this at all, and fill the gap with whatever the person on shift thinks is reasonable.

The gap shows up in a familiar way: a request to reset multifactor sign-in arrives from a personal email address, naming someone else as the account holder. Whether that particular request is legitimate is beside the point. If the process has no step at which it would be caught, the process is the problem.

An account takeover does not usually begin with a technical exploit. It begins with a plausible person asking a helpful person for a reset. Every control in ACC-03 and ACC-04, every phishing-resistant method, every Conditional Access policy, is bypassed entirely if somebody can talk the service desk into handing over access. This procedure is the floor under all of it.

2. Scope — what counts as an account action

Verification is required before any of the following, at every tier:

- Resetting a password, or issuing a Temporary Access Pass.
- Adding, removing or re-registering a multifactor method.
- Unlocking an account.
- Changing group membership, permissions, or mailbox access.
- Retrieving a BitLocker recovery key or any other credential (DEV-01 §9).
- Disclosing account state — including whether an account exists, what its address is, or whether it has MFA registered. This one is easy to overlook and is how an attacker maps the ground.
- Configuring mail forwarding, delegation, or send-as.

- Enabling or disabling an account. Not in scope: answering a general question that reveals nothing account-specific (“how do I set up MFA?”, “what is the password standard?”). Publishing good general answers reduces the number of contacts that need verification at all, which is part of why GOV-05 matters.

3. The rule

> **The rule, in full**
>
> No account action is performed until the requester’s identity has been verified by one of the tiers in §4, and the tier used has been recorded on the ticket.
>
> The verification tier is a required field. A ticket closed without it is an incomplete ticket, regardless of whether the request turned out to be genuine.
>
> This applies to people you know. It applies to senior staff. It applies when the person is standing in front of you and you recognise them — in which case Tier 1 verification takes about four seconds and there is no reason to skip it.
>
> It applies especially when the request is urgent, because urgency is the standard pretext.

One clarification that matters for morale: this is not a statement that staff have been careless. Nobody can follow a procedure that has never been written. The purpose of writing it down is to move the decision off the individual — so that a technician declining to act is following the team’s procedure rather than making a personal judgement they might be argued out of.

4. The four verification tiers

Tier	Method	What it requires	Use when
V1	In person	Government or organization photo ID presented at the desk, checked against the directory record.	Strongest, and often the fastest. Default for anyone on site and mandatory for privileged accounts.
V2	Live video call	Camera on, face visible, photo ID held to the camera, plus two directory facts the requester volunteers without being told which ones you want.	The standard remote path. Anyone working remotely, or anyone off site.
V3	Vouching by a known party	The requester’s manager or department head confirms identity from their own work account, on the ticket. The voucher must already be signed in — which is itself a form of authentication.	The requester cannot do V1 or V2 — no camera, no ID to hand. Never for privileged accounts.
V4	Callback to the directory number	Call the number in the directory record — never a number the requester supplies — plus two volunteered directory facts.	Fallback only. Never alone for a privileged account or for an MFA method change.

5. What each tier requires in practice

5.1 The two facts

V2, V3 and V4 all require the requester to volunteer two facts from the directory record. The technician does not say which facts are wanted. Acceptable facts:

- employee or member ID.
- Department, and the name of their manager.
- The asset tag of their work-issued device.
- Their office or usual work location.
- The month they started with the organization. Not acceptable, because they are discoverable or guessable: date of birth, last four digits of anything, home address, mother's maiden name, or anything published on your website. A fact that an attacker can look up is not a verification.

> **The volunteering matters more than the facts**
>
> A genuine account holder produces two facts readily. An impostor, told which two facts are needed, will frequently produce them too — because the prompt tells them what to research or what to guess at.
>
> So the question is "tell me two things about your record here", not "what is your employee or member ID?". Record which facts they gave, not which you asked for.

5.2 On the photo ID check

Look at the name, look at the photo, look at the person. That is the whole check. Nobody is being asked to detect a forged document — the objective is to defeat a remote impostor who has a name and a plausible story, and holding a matching photo ID to a camera defeats that comprehensively at negligible cost.

6. Requests that are never actioned

Do not action	Because
A request from a outside email address, even one that names the account holder correctly	Anyone can put a correct name in an email.
A request made by a third party on the account holder's behalf, unless that third party is the manager using V3 and the account holder is separately contactable	A helpful colleague and an attacker are indistinguishable at this point in the conversation.
A request where the facts arrive only after you say what you need	The prompt supplied the answer. Nothing was verified.
A request that is urgent and also declines verification	Urgency plus resistance to verification is the signature of the attack, not of a busy person. A genuinely busy person joins a two-minute video call.

Do not action	Because
Adding a new MFA method while an existing method remains registered and reachable	Ask them to use the working method to add the new one (ACC-03 §5.3). Adding a method for someone is how an attacker gets a foothold that survives a password reset.
Any disclosure of account state to an unverified caller — including whether an account exists	It maps the ground for a later attempt.
Anything at all where you feel pressured, hurried, or that something is off	Stop and escalate. See §10.

Declining is not the end of the conversation. Always offer the path that will work: “I can’t action this from an outside address, but I can help you directly — are you able to join a short video call?” The answer is “here is how we can do this”, never “no”.

7. Harder cases

Case	How to handle it
Someone travelling with no photo ID to hand	V3: their manager, sponsor or advisor vouches from their own work account. Common and entirely legitimate.
No camera, or a connection that will not carry video	V3 first. V4 as a fallback, with two volunteered facts.
A person who cannot use video for an accessibility reason	V3, or V1 by appointment. Never treat an accommodation need as a red flag, and never require someone to explain a disability to get their account back. Record the tier used, not the reason.
A new starter who has no directory facts yet	Their manager vouches (V3). This is the normal path on day one and is why ACC-01 §5.2 hands credentials to the manager or in person.
A departing or departed employee requesting access	Do not action. Route to Tier 4 — this is a leaver question (ACC-01 §7), and a request for access after separation needs a decision, not a technician.
Somebody who is angry about being verified	Stay calm, stay friendly, do not waive it. “I know it’s a nuisance — it’s the same check that stops somebody else doing this to your account.” Then escalate to your supervisor rather than negotiating.
A very senior member of staff who declines to verify	The rule does not have a seniority exemption, and senior accounts are the most attractive targets. Escalate to Tier 4 rather than deciding alone — that is exactly what Tier 4 is for.
A request relayed by another IT staff member	The relaying staff member states which tier they used. “Alex asked me to reset it” is not a verification.

8. Privileged accounts

Privileged and administrative accounts require V1 or V2. No vouching, no callback, no exceptions, at any tier. A privileged account is the one an attacker actually wants, and the population is small enough that in-person or video verification is never a real burden.

The same applies to retrieving a BitLocker recovery key, because a 48-digit key handed to the wrong person defeats the encryption entirely (DEV-01 §9).

9. Recording

Field	What goes in it
Verification tier	V1, V2, V3 or V4. Required. The ticket does not close without it.
Facts relied on	Which two facts the requester volunteered. Not their values — "employee or member ID and manager name", not the ID itself.
Voucher, where V3	Who vouched, and confirmation they did so from their own work account.
Number called, where V4	That the directory number was used. Never a number supplied by the requester.
Action taken	What was actually done, and by whom.
Declined requests	Recorded too, with the reason and what was offered instead. A pattern of declined requests against one account is a security signal that is invisible if declines are not logged.

10. Pressure, and what to do about it

> **If it feels wrong, it is enough that it feels wrong.**
>
> Nobody will be criticised for verifying, for taking an extra two minutes, or for escalating a request they were not comfortable with. That is written here so it can be pointed at.
>
> The technician who is talked out of a verification is not the person who failed. The organisation that left them alone with the decision is. This procedure exists so that the answer is "our procedure requires it" rather than "I would rather not".
>
> Escalate to your supervisor, or to Tier 4, and say plainly that something felt off. An attempt that is escalated and turns out to be genuine costs somebody four minutes. An attempt that is actioned and turns out not to be genuine costs considerably more.

11. Training and refresh

1. Every person at every tier who can take an account action reads this document and Appendix A before their first shift.
2. Tier 1 technicians re-read it every quarter, because people change and this is the tier attackers call.
3. The department runs one deliberate practice attempt per quarter — a colleague calls the desk with a plausible unverified request. The purpose is to find out whether the procedure holds, not to catch anybody out, and the result is discussed openly with no individual named.
4. Every real attempt is written up and circulated, with the story of what the caller said. Specifics teach; policy statements do not.

12. Measurement

- Share of account-action tickets with a verification tier recorded. Target: 100%. Anything less means the field is optional in practice.
- Distribution across V1–V4. A heavy skew to V3 and V4 suggests V2 is impractical for some reason worth understanding.
- Declined requests per month, and how many later completed legitimately. Both numbers are healthy; zero declines is the number to worry about.
- Practice-attempt outcomes per quarter.

13. Records

Record	Held in	Retention
Verification tier and facts relied on	Ticket — required field	3 years
Declined requests, with reason and what was offered	Ticket	3 years
Suspected social-engineering attempts	Security record (GOV-03)	7 years
Practice-attempt results	Training record	3 years
Confirmation of reading, per staff member per quarter	Training record	Duration of employment

14. Related documents

ID	Title	Relationship
ACC-03	MFA Enrollment, Reset & Account Recovery	§6 of that document is the summary; this is the full standard. Method changes are the highest-risk action here.
ACC-04	Password Standard & Self-Service Password Reset	Self-service removes the need for verification entirely, which is the best possible outcome.
ACC-05	Account Lockout Triage	Verification precedes any restoration.
ACC-07	Privileged & Administrative Account Standard	§8 applies to every account it governs.
ACC-01	Account Lifecycle	§5.2 credential handover, and the §7 leaver case in §7 above.
DEV-01	Device Enrollment & Lifecycle	Recovery-key retrieval is an account action (§2, §8).
GOV-03	Security Incident Response & Escalation Matrix	Where a suspected attempt goes.
GOV-05	Knowledge Base Article Standard	Format for the end-user explanation of why verification is asked for.

Appendix A — The verification script

Read this before any account action. Nine lines. It takes under two minutes.

	Say / do
1	“Before I make any change to the account, I need to check who I’m speaking to. I can do that here at the desk, or on a quick video call — whichever is easier for you.”
2	Request from a outside address? “I can’t action a request from an outside address, but I can help you directly. Can you join a short video call?” Do not continue on the email thread.
3	On video: “Please turn your camera on and hold your photo ID up.” Check name, photo, person. That is the whole check.
4	“Without me prompting you, tell me two things about your record here — anything you like.” Do NOT list what you are expecting. Note which two they gave.
5	Cannot do either? “I can accept confirmation from your manager instead — may I copy them on the ticket?” That is V3, and the manager must reply from their own work account.
6	Before acting: is the password even the problem? Run the ACC-05 triage card first.
7	Act. Prefer a Temporary Access Pass over a temporary password.
8	Record: verification tier, which facts they volunteered, action taken, and the confirmed ACC-05 cause.
9	Confirm they have signed in successfully. Then close.

Stop and escalate if: the request is urgent AND they resist verifying; a third party is pressing on someone’s behalf; the facts only arrived after you said what you needed; or anything simply feels off. You will never be criticised for verifying.

Appendix B — What to say when declining

Declining well keeps the person on side. Every line below ends with a way forward.

Situation	Words that work
Request from a personal address	“I’m not able to action account changes from an outside address — that’s the same rule that stops someone else doing it to your account. I can sort this out with you on a two-minute video call though. What works?”
They are in a hurry	“I understand, and I’d rather not slow you down — the check takes about ninety seconds and then I can get straight into it.”
A colleague asking on someone’s behalf	“I can’t make the change on someone else’s account, but if you can put me in touch with them directly I’ll get it done now. Or if you’re their manager, you can confirm their identity on the ticket and that works too.”
They push back on principle	“It’s our procedure rather than my call, and it applies to everybody — including our own staff. Let me get it done quickly and then we can fix the actual problem.”

Situation	Words that work
They stay angry	“I hear you, and I’m not going to be able to waive it. Let me bring my supervisor in so you’re not stuck with me on this.” Then escalate. Do not negotiate.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.